CyberDefenders

Resolución de Laboratorio

JetBrains

Análisis de una captura de tráfico de un servidor TeamCity comprometido: identificación del atacante, explotación de una vulnerabilidad de autenticación, instalación de un webshell, ejecución de comandos y escape al sistema anfitrión con Docker.

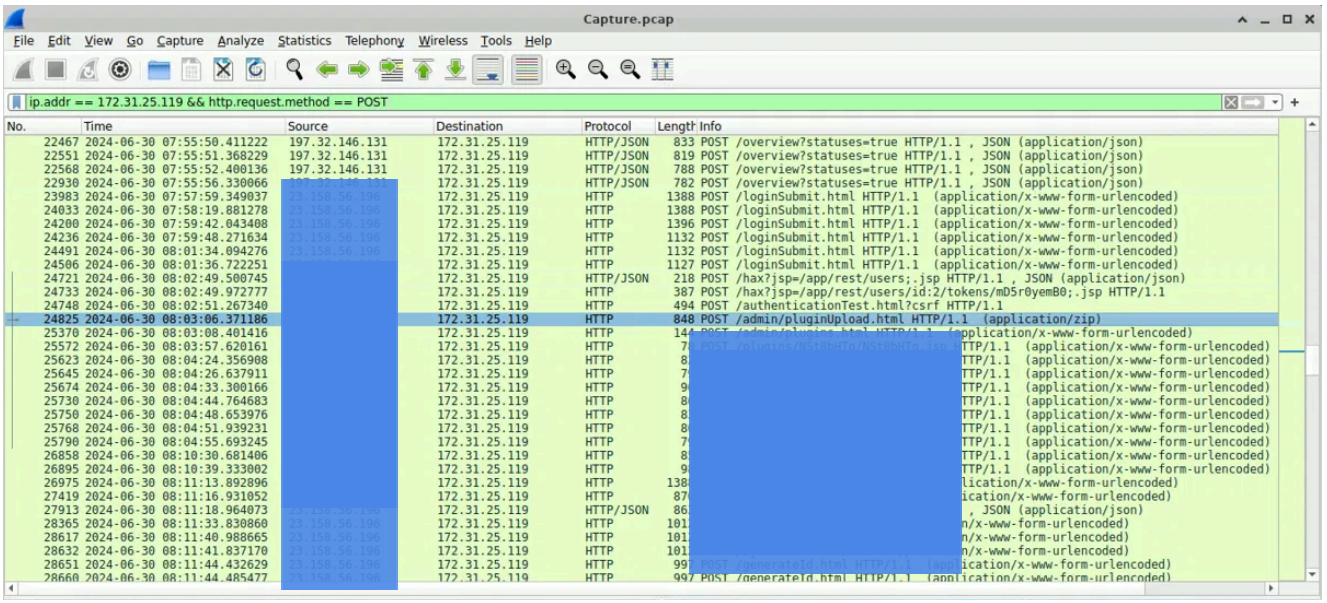
URL:
https://cyberdefenders.org/blueteam-ctf-challenges/jetbrains/

Writeup por Jenrrisinho

Noviembre 2026

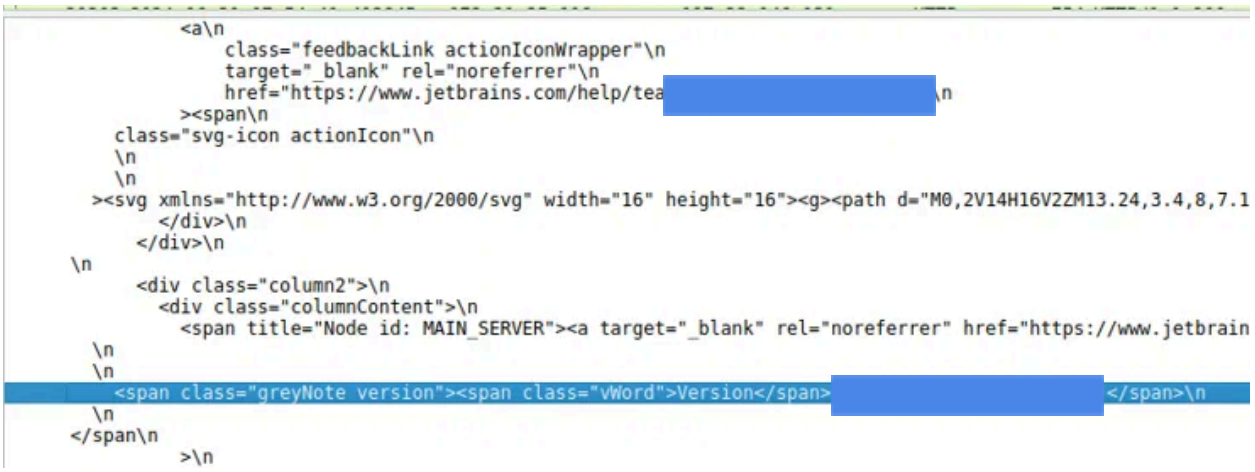
Pregunta 1: IP del atacante

Con el filtro *`ip.addr == <ip_victima> && http.request.method == <metodo>`* se ve que la víctima recibe desde <ip_atacante> toda la cadena de ataque: intentos de login en `/loginSubmit.html`, las peticiones `/hax?jsp=...`, la subida en `/admin/pluginUpload.html` y los POST a un archivo `.jsp` con nombre aleatorio.



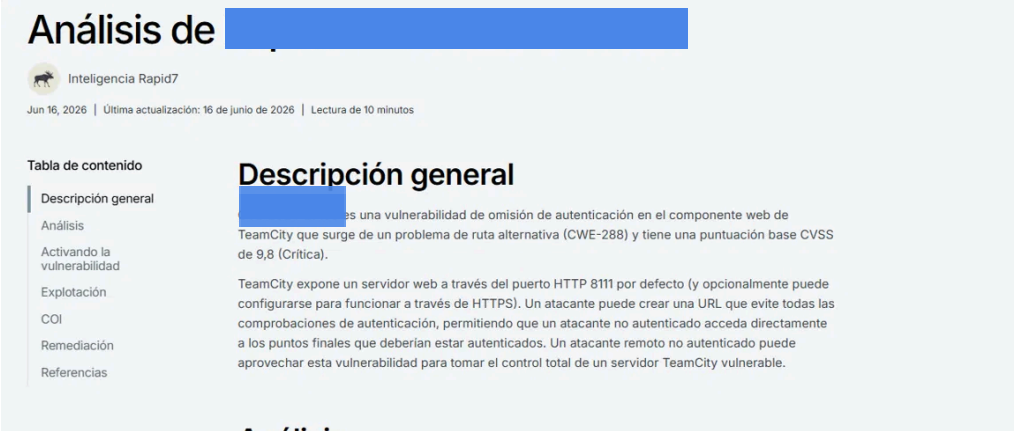
Pregunta 2: Versión del servidor web

El servicio del puerto 8111 es TeamCity (la víctima consulta dominios de jetbrains.com). La versión se encuentra en el HTML de una respuesta del servidor, filtrando con `ip.addr == <ip_victima> && http contains "Version"`.



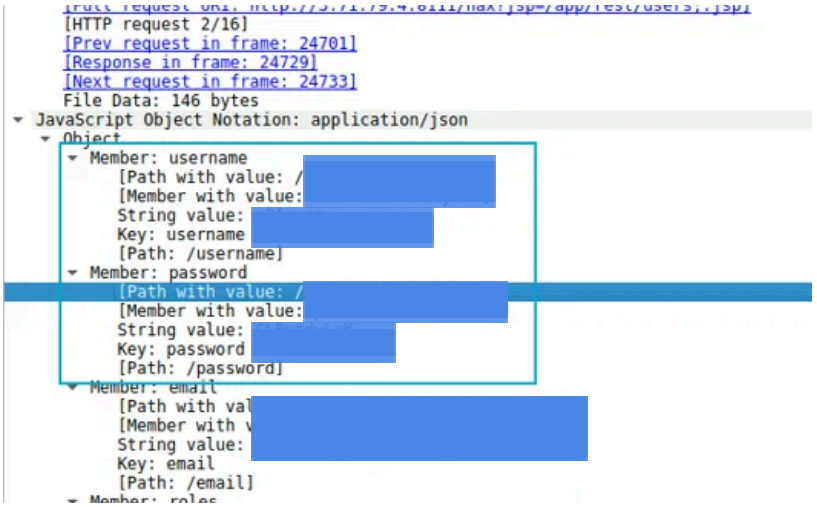
Pregunta 3: CVE explotado

Es una omisión de autenticación (CWE-288, ruta alternativa) con CVSS 9.8. El atacante agrega `;.jsp` al final de la ruta y el parámetro `jsp` hace que TeamCity salte las comprobaciones de autenticación, lo que permite llamar a endpoints REST sin credenciales. Es el patrón exacto de las peticiones `/hax?jsp=/app/rest/users;.jsp`.



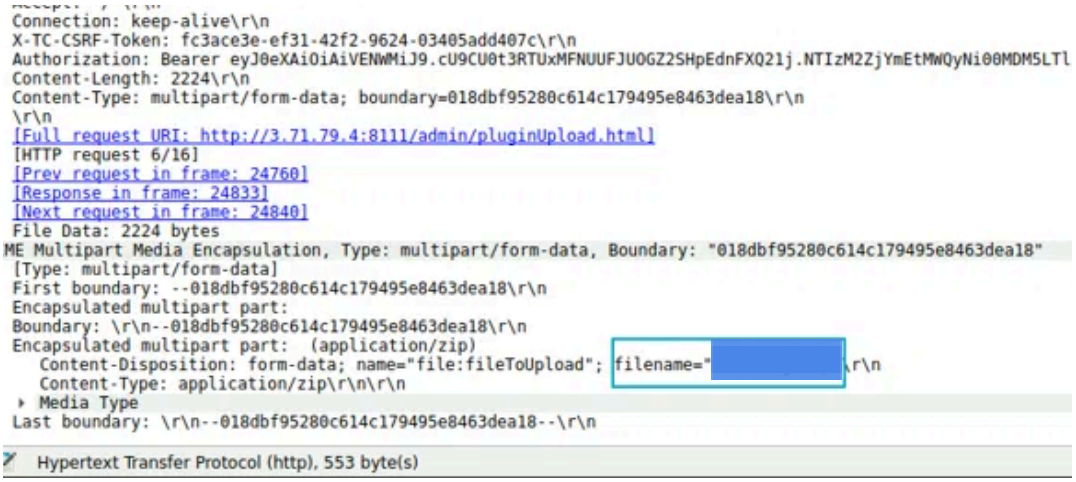
Pregunta 4: Credenciales creadas por el atacante

En el frame 24721 el cuerpo contiene `username`, `password`, `email` y un rol asignado. Es decir, el atacante usó el bypass para **crearse una cuenta propia con privilegios**. Justo después, en el frame 24733, genera un token, que luego usa como `Authorization: Bearer` en sus siguientes peticiones.



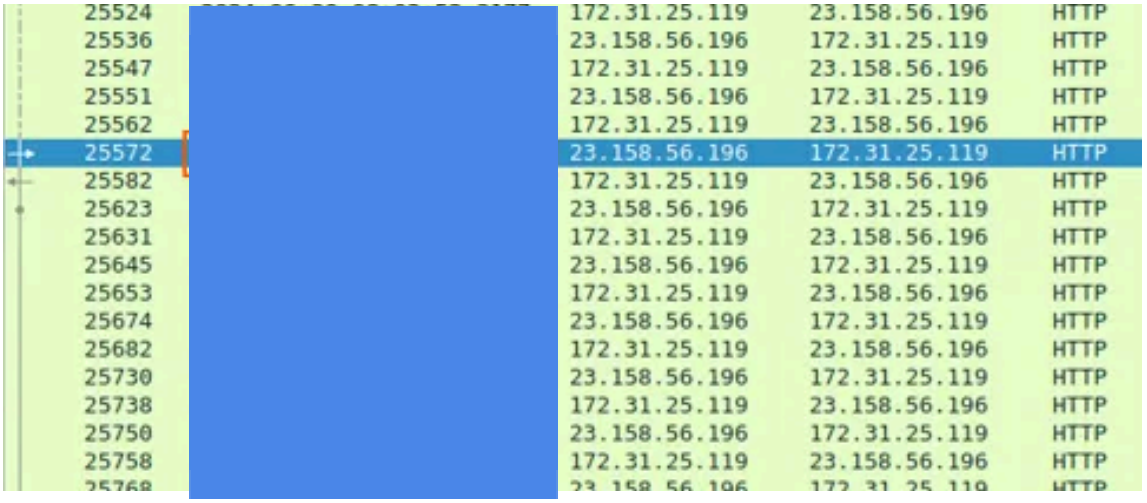
Pregunta 5: Webshell subido

El frame 24825 es un POST `multipart/form-data` a `/admin/pluginUpload.html` con `filename="<archivo.zip>"`, autenticado con el token Bearer y el `X-TC-CSRF-Token`. El servidor responde 200 y el atacante instala el plugin desde `/admin/plugins.html`. Después empieza a hacer POST a `/plugins/<archivo>/<archivo.jsp>`: el nombre aleatorio se repite en el zip, la carpeta del plugin y el `.jsp`, lo que sirve como indicador de detección.



Pregunta 6: Primer comando por el webshell

El frame 25572 es el primer POST a `/plugins/<archivo>/<archivo.jsp>`. En el cuerpo se ve `cmd=ls`: el atacante lista el directorio. Los GET anteriores a `/authenticationTest.html` con respuesta 401 vienen de otro puerto de origen y no son comandos del webshell.

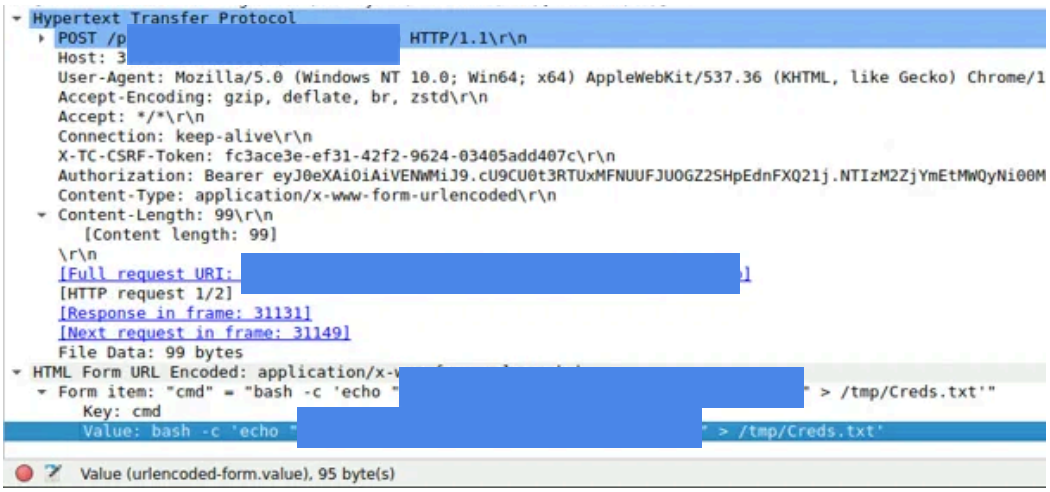


Pregunta 7: Archivo de credenciales alterado

En el frame 31123, el formulario decodificado muestra el valor de cmd:

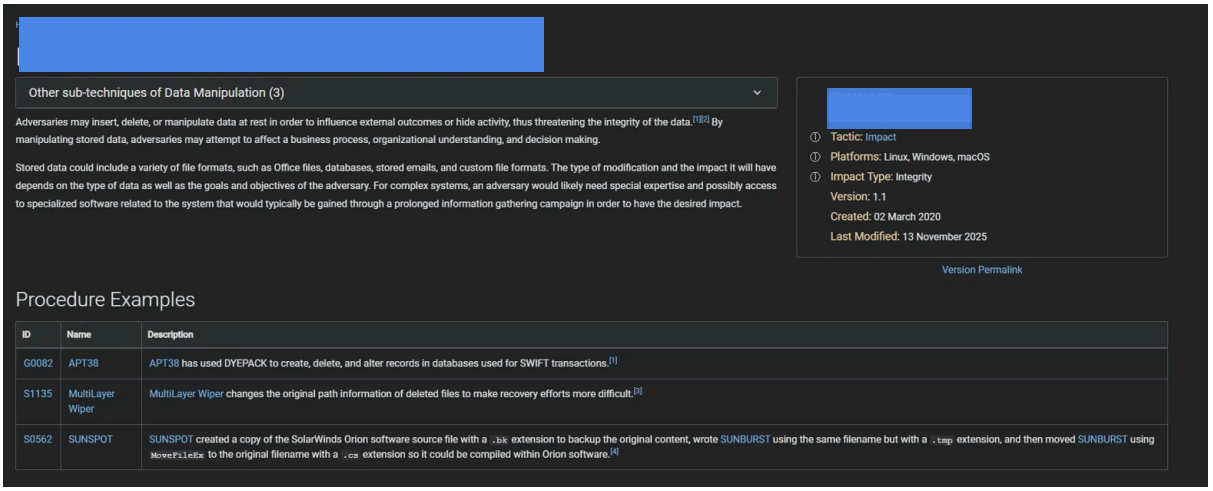
```
bash -c 'echo "username:<usuario>,password:<password>" > /tmp/Creds.txt'
```

El > **sobrescribe** el archivo, reemplazando las credenciales originales del administrador por unas falsas.



Pregunta 8: Técnica MITRE ATT&CK

El atacante modifica datos que están guardados en el sistema (el contenido de un archivo) para alterar su integridad. Tactic: Impact; Impact Type: Integrity.



Pregunta 9: Escape al host

En el frame 32111 el atacante monta el sistema de archivos del servidor dentro de un contenedor y cambia la raíz hacia él, quedando con acceso root al host.

